

Backend - Single Person Role

ATDP | Node/Express + SQLite | Navi Mumbai demo (28 vehicles, 10 showrooms)

1. Overview & Scope

Full backend ownership for ATDP (PROJECT_DOCUMENTATION.txt:3 -- 8 phases, 5 tables, 25+ endpoints, Aston Martin design system). Serves frontend statically at `http://localhost:5000` plus JSON API. Database: SQLite via better-sqlite3 (MySQL in production docs) with FKs, unique (vehicle_id, showroom_id, booking_date, time_slot), JWT 7d, bcrypt 12 rounds.

2. Technology Stack

Node.js 22 + Express 4.18, better-sqlite3 9.1, jsonwebtoken 9.0, bcryptjs 2.4, express-validator 7.0, helmet 7.1, morgan 1.10, express-rate-limit 7.5 (1000/15min /api, 100/15min /auth), cors 2.8. Frontend served from backend/server.js:31 `express.static(frontend)`.

3. Files Owned (backend/*)

- **backend/server.js:1-51**
Express app, helmet/cors/morgan, rateLimit (apiLimiter skip /api/auth, authLimiter), route mounting, GET /api/health, static frontend + catch-all, error handler, listen PORT 5000.
- **backend/config/db.js:10**
initDb() -- inline schema fallback (users, brands, vehicles, showrooms, bookings + admin_message), WAL + FK ON, db pragma. Migration adds admin_message if missing.
- **backend/seed.js:12-130**
10 brands with local /img/logos/*.svg, 28 vehicles (Rs 8.99L-68.5L on-road Navi Mumbai, ZigWheels/CarDekho), 10 showrooms (Vashi, Nerul, Kharghar...), 2 users (admin@autoportal.com / Admin@123 + john@example.com / John@123), 5 demo bookings (pending/approved/cancelled/completed with admin_message).
- **backend/middleware/auth.js:1**
authenticate (Bearer JWT verify), authorizeAdmin (role check), JWT_SECRET fallback.
- **backend/utils/helpers.js:1**
paginate(page, limit) -> {page, limit, offset}, timeSlots() 9 slots 09-18.
- **backend/routes/auth.js:1**
POST /register (name, email, password, phone, address -> hash -> JWT), POST /login (bcrypt.compare), GET/PUT /profile, PUT /change-password. Validation via express-validator.
- **backend/routes/vehicles.js:34**
GET / (filter: category, brand_id, fuel_type, max_price/min_price, status, search + paginate), GET /brands, GET /:id (+ auto_showroom), POST/PUT/DELETE (admin only). Fuel_type added for Hybrid/Petrol dropdown.
- **backend/routes/showrooms.js:1**
GET ?city=&state=&brand_id, GET /cities, GET /:id, POST/PUT/DELETE (admin, brand linkage for auto-assign).
- **backend/routes/bookings.js:12**
GET /available-slots?showroom_id=&booking_date, GET / (own vs admin all), GET /:id, POST (auto showroom by brand_id, future-date, 9 slots, no double-book via UNIQUE), PUT /:id {status, admin_message} (customer only cancel, admin approve/reject with message), DELETE.
- **backend/routes/admin.js:9**
GET /dashboard (counts: users, customers, vehicles, showrooms, bookings, pending/approved/completed/cancelled, recentBookings, brandInventory), GET /users/bookings/inventory, PUT/DELETE /users/:id.

4. API Endpoints Summary (25+)

Auth: POST /api/auth/register, POST /api/auth/login, GET /api/auth/profile, PUT /api/auth/profile, PUT /api/auth/change-password
Vehicles: GET /api/vehicles?category=&brand_id=&fuel_type=&max_price=&status=&search=&page=&limit=, GET /api/vehicles/brands, GET /api/vehicles/:id, POST/PUT/DELETE /api/vehicles (admin)
Showrooms: GET /api/showrooms?city=&state=&brand_id, GET /api/showrooms/cities, GET /api/showrooms/:id, POST/PUT/DELETE /api/showrooms (admin)
Bookings: GET /api/bookings?status&page&limit, GET /api/bookings/available-slots, GET /api/bookings/:id, POST /api/bookings, PUT

/api/bookings/:id {status,admin_message}, DELETE

Admin: GET /api/admin/dashboard, GET /api/admin/users, GET /api/admin/bookings, GET /api/admin/inventory, PUT/DELETE /api/admin/users/:id

Health: GET /api/health

5. Key Business Rules to Enforce

- Vehicle availability

Only status=available can be booked (backend/routes/bookings.js:80).

- Future dates

booking_date >= today (setHours 0,0,0,0) else 400.

- Auto showroom

If showroom_id missing, SELECT id FROM showrooms WHERE brand_id=vehicle.brand_id LIMIT 1 else 400 No showroom.

- No double-book

UNIQUE (vehicle_id,showroom_id,booking_date,time_slot) + UNIQUE (user_id,booking_date,time_slot) -> 409 with specific messages.

- Slots

timeSlots() 09:00-18:00, validate includes, availableSlots = all - booked where status != cancelled.

- Status flow

pending -> approved/cancelled, approved -> completed/cancelled, customers only cancel own pending/approved, admin can set any with admin_message (congrats/reason visible in dashboard).

- Forced login

Frontend vehicle.html enforceLogin() redirects to login.html?redirect=... with User/Admin tabs, Admin security 1234 (frontend check, not shown in demo creds).

6. Security

JWT Bearer 7d (localStorage), bcrypt 12 salt rounds, express-validator, helmet headers, cors, parameterized queries (SQLi), rate-limit (auth 100/15min, api 1000/15min, static bypass), role-based access (admin vs customer), XSS via helmet/cors.

7. Effort & Timeline (solo backend)

Schema + seed 1d, Auth (register/login/JWT/bcrypt) 2d, Vehicles/Showrooms CRUD 3d, Bookings (slots, auto-assign, double-book) 3d, Admin dashboard 2d, Rate-limit/helmet/testing 2d => ~12-14 days. Frontend parallel saves ~10d. Total project 3-4 weeks solo, 2 weeks with 2 devs.

8. Skills Required

Node.js, Express, SQL/SQLite (FKs, UNIQUE, JOINS), JWT, bcrypt, Validation, REST, CORS, Postman/curl testing. Bonus: Chart.js for admin, Aston Martin tokens for frontend collaboration.

9. Run & Test

cd backend && npm install && node seed.js && node server.js # http://localhost:5000

Demo: john@example.com / John@123 (customer), admin@autoportal.com / Admin@123 + security 1234 (Admin tab)

Test: curl -s http://localhost:5000/api/health; curl -s http://localhost:5000/api/vehicles?fuel_type=Hybrid&limit=9